

Security questionnaire — pre-filled answers

Drop-in answers to the questions a financial-services vendor questionnaire usually asks. Keep answers honest; where there's a gap, say so + the plan.

Draft for review. See `README.md` .

Question	Answer
What personal data do you process, and for whom?	See <code>01_data-flow-and-residency.md</code> . We are processor; the client is controller.
Where is data stored / processed?	At rest: EU (Turso, Ireland). Compute: EU (Vercel, Frankfurt). AI processing: US (Anthropic) under SCCs, no training, 30-day deletion.
Is data encrypted in transit and at rest?	Yes. TLS on every connection; AES-256 (Vercel) / volume + optional page-level AES/AEGIS-256 (Turso) at rest.
Do you offer a DPA?	Yes — see <code>03_DPA-template.md</code> (or we sign the client's).
Do your sub-processors offer DPAs / SCCs?	Yes (Anthropic, Vercel); Turso DPA is request-based and obtained per engagement. See <code>02_subprocessor-list.md</code> .
International transfers — what safeguards?	SCCs. Vercel is DPF-certified. Anthropic DPF status to be confirmed per engagement.
Is our data used to train AI models?	No. Anthropic does not train on commercial/API data.
What is your data-retention policy?	See <code>04_retention-and-deletion.md</code> . AI-side: 30-day auto-deletion (mandatory on the current model).
Can you delete our data on request (right to erasure)?	Yes — working erasure process; immediate in our store, ≤30 days across all systems.
Access control?	Auth on all facilitator routes; client access via per-sprint tokens. Gap: shared team password / no per-user accounts yet — remediation planned before first client (<code>05_...</code>).
MFA?	Not yet — planned with per-user accounts.
Audit logging?	Not yet — planned (<code>05_...</code>).
Backups?	Yes (<code>npm run backup</code>); scheduling planned.
Certifications (yours)?	Unloct holds none yet (early-stage). Sub-processors: Vercel & Turso SOC 2 Type II + ISO 27001; Anthropic SOC 2 II / ISO 27001 / ISO 42001 (confirm current).
Incident response / breach notification?	We notify the controller within [24/48]h of awareness (DPA §7). Formal IR runbook: planned (<code>05_...</code>).
Penetration testing?	Not yet for this platform; planned before scaling past the pilot.
Automated decision-making affecting individuals (Art. 22)?	No. AI output is advisory and human-reviewed; it designs product concepts, not decisions about people.
Sub-contractors / where is the team?	Small EU-based team; access on need-to-know.

Honesty note: several "not yet" answers above are early-stage gaps with named remediation in 05_security-measures-TOMs.md . Presenting them with a plan is the right move for a pilot — do not paper over them.